TLP:CLEAR Unrestricted public release.

CYBER THREAT INTELLIGENCE REPORT

PHP2Shell: two critical PHP RCE flaws now confirmed exploited, added to CISA KEV

From **Cybersecurity Briefing - 2026-10-27** · 2026-10-22 to 2026-10-27 · Briefing generated 2026-10-27

REPORT ID	VERSION	HANDLING
LIT-CTI-20261027-03	1.1 · 2026-10-27 10:42 EDT	TLP:CLEAR
BRIEFING SECTION	**ORIGINAL PUBLISHED**	**LAST UPDATE**
United States	2026-10-21	2026-10-27
CVES	**ANALYST**	
CVE-2026-109618 (CVSS 9.2), CVE-2026-109619 (CVSS 9.2)	Nick Sturgeon	

VULNERABILITY | CRITICAL | ACTIVELY EXPLOITED | OVERALL CONFIDENCE: HIGH

BOTTOM LINE UP FRONT

PHP2Shell is the name for two flaws in the PHP engine itself: CVE-2026-109618 (memory corruption after out-of-memory error handling) and CVE-2026-109619 (stale internal request state). Both are rated CVSS v4.0 9.2 and allow unauthenticated remote code execution [S3] [S4]. Every PHP installation that serves web requests is in scope, including Apache mod_php, PHP-FPM, php-cgi, FrankenPHP and LiteSpeed. PHP rates mod_php as the highest risk [S1] [S12]. PHP fixed both flaws on 2026-10-21 in 8.5.12, 8.4.27, 8.3.36 and 8.2.35. Branches 8.1 and older get no official updates; PHP published only minimal source backports for 7.4, 8.0 and 8.1 [S1] [S12]. Wiz Research reported the bugs to PHP in August 2026 and says nearly every PHP release back to 5.4 carries at least one of them [S9].

Scanning began before the patch and grew quickly. Cloudflare reported millions of attempts by early 2026-10-22 [S11]. On 2026-10-24, researcher Adel Karimi confirmed working exploitation: three honeypots running PHP 8.4.26 under single-worker mod_php recorded 35 shells from two source IPs. The traffic matched a public proof-of-concept and is consistent with CVE-2026-109618 [S5] [S6]. Karimi stresses that this setup was deliberately favorable and does not measure reliability against other worker counts or builds [S5] [S7]. CISA added both CVEs to the Known Exploited Vulnerabilities catalog on 2026-10-26. The federal due date is 2026-10-29, and ransomware use is listed as Unknown [S2]. EPSS scores on 2026-10-26 were 0.99981 and 0.99997 [S13]. Censys estimates more than 32.5 million PHP services on affected versions; Palo Alto Xpanse counts about 22.6 million exposed instances [S7] [S10].

Some claims remain unconfirmed or have been withdrawn. On 2026-10-25, Unit 42 retracted its report linking an intrusion at a European government agency to PHP2Shell [S10]. Sophos corrected an earlier statement that a Potassium (Mirai-derived) botnet install had succeeded. Arctic Wolf tied Potassium binaries to servers hosting PHP2Shell tooling, but its data does not show PHP2Shell requests delivering the malware [S11]. No threat actor has been named. Industrial and appliance vendors are still checking products that bundle PHP. Schneider Electric, ABB/B&R, Johnson Controls, Belden, HMS, Wibu-Systems and Siemens (RUGGEDCOM APE1808) have confirmed affected products, and some of them have no patch yet [S8].

What to do: inventory every PHP runtime, including PHP bundled inside appliances, CMS hosting, control panels and OT or building-management products. Patch internet-facing systems first. Take offline any system that cannot be patched quickly or runs PHP 8.1 or earlier [S1]. Use WAF/CDN vendor rules and PHP's interim php.ini hardening only as temporary measures [S12] [S9]. Hunt for web server or PHP worker processes spawning shells, for memory-exhaustion errors at request startup, for worker segfaults, and for oversized PHPSESSID cookies [S5] [S9] [S1].

Key judgments

LIKELY · MODERATE CONFIDENCE
Successful PHP2Shell exploitation against production (non-honeypot) systems is likely to be publicly confirmed within the next two weeks, because public exploits are maturing and opportunistic scanning continues at scale. [S5] [S6] [S11] [S2]

VERY LIKELY · HIGH CONFIDENCE
PHP bundled in appliances, OT and building-management products, and hosted platforms is very likely to stay vulnerable well past the KEV due date. Several vendors have no fix yet, and owners often do not know these products contain PHP. [S8] [S1] [S3]

LIKELY · LOW CONFIDENCE
Exploitation against multi-worker production deployments is likely to be less reliable than the single-worker honeypot results. Defenders should expect many failed attempts that show up as memory errors and worker crashes, not clean compromises. [S5] [S9] [S11]

ROUGHLY EVEN CHANCE · LOW CONFIDENCE
There is a roughly even chance that a ransomware or initial-access-broker operation will be publicly tied to PHP2Shell within 30 days. No such link is confirmed today, and the only government-intrusion claim was retracted. [S2] [S10] [S11]

INDICATORS OF COMPROMISE

Honeypot indicators (source IPs, request-body hashes, log signatures, process behavior, proof-file names) come from Adel Karimi's report of 2026-10-24 [S5]. Botnet and tooling infrastructure comes from Sophos, Wordfence, SOCRadar and Hunt.io data as compiled by The Hacker News around 2026-10-22/23 [S11]. Source IPs rotate

quickly, so treat IP blocks as short-lived and rely on behavioral detection. Potassium infrastructure has not been proven to deliver malware through PHP2Shell.

Type	Indicator (defanged)	Context	Provenance	First seen	Source
ipv4	`15[.]204[.]59[.]70`	Confirmed exploitation source (OVH US). Produced 3 shells on one honeypot, 15:35-16:04 UTC.	REPORTED	2026-10-24	[S5] [S6]
ipv4	`162[.]35[.]99[.]94`	Confirmed exploitation source (Interserver). Produced 32 shells across three honeypots, 16:46-18:57 UTC.	REPORTED	2026-10-24	[S5] [S6]
ipv4	`104[.]28[.]208[.]84`	Attempt-only source: its requests caused PHP errors or worker crashes, with no confirmed shell.	REPORTED	2026-10-24	[S5]
ipv4	`144[.]48[.]4[.]242`	Attempt-only source: its requests caused PHP errors or worker crashes, with no confirmed shell.	REPORTED	2026-10-24	[S5]
sha256	`8e8fc166e6b326d20bb7611d8ef3cee3bd5da46447985312c1492ab0a44d1eb6`	Hash of a decoded multipart request body seen in the exploitation traffic. Hunt in WAF or packet-capture tools that hash request bodies.	REPORTED	2026-10-24	[S5]
sha256	`b6c547e0e9a2bb26607df1521de96f4d5c9adf4621c28b7ab491587b21ae40f2`	Hash of a decoded multipart request body seen in the exploitation traffic.	REPORTED	2026-10-24	[S5]
sha256	`7af66c8f35c5fa6b47a539da6dca361d19543d9f62d61e4af891c2802bd5e236`	Hash of a decoded multipart request body seen in the exploitation traffic.	REPORTED	2026-10-24	[S5]
sha256	`aab24fa5ec0df76f731c1ea4bac9fd36aa350eef9a42c33315e485178e1e5892`	Example body hash from the final request. These hashes vary per target; the report lists about 14.	REPORTED	2026-10-24	[S5]
sha256	`e538361aa02f01bb9e00f53d2107eb1369f778203033e08506496a767c0e4abc`	Second example body hash from the final request.	REPORTED	2026-10-24	[S5]

Type	Indicator (defanged)	Context	Provenance	First seen	Source
other	`PHP log: Allowed memory size of 134217728 bytes exhausted ... in Unknown on line 0`	Memory exhaustion logged at request startup, before application code runs. The byte value reflects a 128 MiB memory_limit and will differ elsewhere. Not proof of compromise on its own.	REPORTED	2026-10-24	[S5]
other	`PHP Request Startup: Session ID is too long or contains illegal characters`	PHP warning seen alongside oversized PHPSESSID values in the attack traffic.	REPORTED	2026-10-24	[S5]
other	`Apache error log: Segmentation fault (11) on a child worker`	Worker crash shortly after the shell started. The last request often has no completed access-log entry.	REPORTED	2026-10-24	[S5]
command	`apache2 (uid 33) spawning /bin/sh, followed by id, php, curl or wget`	Process lineage recorded with Tetragon. On PHP-FPM hosts, expect php-fpm as the parent instead (derived).	REPORTED	2026-10-24	[S5] [S1]
http-request	`POST to / or /index.php, multipart/form-data, no User-Agent header, unusually large bodies`	General shape of the observed attack requests. A 200 response does not reliably mean success.	REPORTED	2026-10-24	[S5]
http-request	`Oversized or malformed PHPSESSID cookie in request or Set-Cookie response`	Both the honeypot report and Wiz flag this as a detection signal.	REPORTED	2026-10-24	[S5] [S9]
filepath	`/tmp/x1`	Temporary proof-of-execution file.	REPORTED	2026-10-24	[S5]
filepath	`/var/www/html/p1`	Proof file the attacker tried to write in the web root (blocked on the honeypots by a read-only filesystem).	REPORTED	2026-10-24	[S5]
filepath	`/var/www/p1`	Alternate proof-file location the attacker tried.	REPORTED	2026-10-24	[S5]

Type	Indicator (defanged)	Context	Provenance	First seen	Source
port	`8080`	Outbound callbacks from web worker children to attacker hosts used ports 80, 8080 and 8081.	REPORTED	2026-10-24	[S5]
ipv4	`134[.]199[.]154[.]64`	Potassium (Mirai-derived) C2 address. Delivery through PHP2Shell is not proven.	REPORTED		[S11]
domain	`thunder[.]godofthunder[.]st`	Potassium C2 domain; C2 channel on TCP 50792.	REPORTED		[S11]
port	`50792`	TCP port of the Potassium C2 channel.	REPORTED		[S11]
ipv4	`92[.]118[.]112[.]100`	Loader/staging server linked to the Potassium attempt.	REPORTED		[S11]
ipv4	`85[.]11[.]167[.]243`	Attack source in the Potassium-related PHP2Shell attempts (Sophos).	REPORTED		[S11]
ipv4	`217[.]60[.]242[.]76`	Attack source in the Potassium-related PHP2Shell attempts (Sophos).	REPORTED		[S11]
ipv4	`45[.]198[.]224[.]169`	Attack source in the Potassium-related PHP2Shell attempts (Sophos).	REPORTED		[S11]
ipv4	`206[.]188[.]197[.]105`	Open directory hosting PHP2Shell tooling on port 9999 (SOCRadar/Hunt.io). The source lists 12 more open-directory hosts.	REPORTED		[S11]
ipv4	`87[.]121[.]84[.]174`	Exploit-attempt source listed by Wordfence.	REPORTED		[S11]
ipv4	`181[.]215[.]186[.]252`	Exploit-attempt source listed by Wordfence.	REPORTED		[S11]
ipv4	`185[.]196[.]220[.]132`	Exploit-attempt source listed by Wordfence.	REPORTED		[S11]
other	`Palo Alto NGFW threat ID 543004 (also 97622-97625)`	Vendor signature IDs for PHP2Shell attempts; use them to query existing firewall threat logs.	REPORTED	2026-10-21	[S10]

Indicators are defanged (hxxp, [.], [@]) so they cannot be clicked. "Reported" means stated in a source; "Derived" means inferred by the analyst from the source material and should be validated before blocking.

TACTICS, TECHNIQUES & PROCEDURES (TTPS)

Attackers send unauthenticated HTTP requests to any PHP-served page. These requests trigger memory-handling bugs in the PHP engine and leave a worker process in a corrupted state. On a vulnerable and suitably configured server, this ends in command execution as the web server user [S3] [S4] [S5]. In the confirmed honeypot cases the attacker ran simple proof commands, wrote small proof files, and made callbacks to its own hosts. No second-stage payload was seen [S5] [S6]. Separately, botnet operators have tried to use the flaws to install Potassium (Mirai-derived) DDoS malware, but successful delivery is unproven [S11]. Failed attempts are common and appear as memory-exhaustion errors and worker crashes [S5] [S11].

MITRE ATT&CK mapping

Tactic	Technique	Procedure observed	Detection opportunity
Reconnaissance	T1595.002 Active Scanning: Vulnerability Scanning	Mass internet scanning for PHP-served sites began before the patch release and reached millions of attempts within a day. [S11] [S10]	Spikes in multipart POSTs with no User-Agent from many sources; vendor WAF and IPS signatures.
Initial Access	T1190 Exploit Public-Facing Application	Unauthenticated requests exploit CVE-2026-109618 and/or CVE-2026-109619 in the PHP runtime. [S1] [S3] [S4] [S5]	Memory-exhaustion errors at request startup, oversized PHPSESSID values, worker segfaults, NGFW threat ID 543004.
Execution	T1059.004 Command and Scripting Interpreter: Unix Shell	The web server worker (uid 33) spawned /bin/sh, which ran follow-on commands. [S5] [S1]	Alert on apache2, httpd, php-fpm or lsphp parents spawning sh or bash.
Discovery	T1033 System Owner/User Discovery	The attacker ran the id command to confirm execution context. [S5]	id or whoami launched by a web server process tree.
Command and Control	T1071.001 Application Layer Protocol: Web Protocols	Children of the web worker made HTTP callbacks to attacker hosts on ports 80, 8080 and 8081 as proof of execution. [S5]	Outbound connections initiated by web server child processes; egress filtering alerts.
Command and Control	T1105 Ingress Tool Transfer	curl and wget were invoked from the shell. Potassium loader servers were linked to the campaign, but no successful download is confirmed. [S5] [S11]	curl or wget launched by a web server process tree; connections to listed loader IPs.
Impact	T1499.004 Endpoint Denial of Service: Application or System Exploitation	Exploit attempts exhaust memory and crash PHP workers, which degrades service even when they fail. [S5] [S9]	Worker crash and respawn rates, repeated HTTP 500s, PHP fatal-error volume.

Tactic	Technique	Procedure observed	Detection opportunity
Impact	T1498 Network Denial of Service	Potassium supports 24 flood commands over ICMP, TCP, UDP and OpenVPN. Its use through PHP2Shell is attempted but unproven. [S11]	Unusual outbound flood traffic from web servers; connections to the Potassium C2 on TCP 50792.

Detection & hunting

Queries are built from the reported behavior and indicators. They are untested; tune field names for your environment.

Web server or PHP worker spawning a shell (Linux) `SIGMA`

```
title: Web Server Process Spawning Shell (PHP2Shell hunting)
status: experimental
logsource:
  product: linux
  category: process_creation
detection:
  selection_parent:
    ParentImage|endswith:
      - '/apache2'
      - '/httpd'
      - '/php-fpm'
      - '/lsphp'
      - '/frankenphp'
  selection_child:
    Image|endswith:
      - '/sh'
      - '/bash'
      - '/dash'
      - '/curl'
      - '/wget'
      - '/id'
  condition: selection_parent and selection_child
falsepositives:
  - Legitimate PHP applications that call system utilities
level: high
```

Based on the process lineage in S5 and CISA's monitoring advice in S1. Baseline legitimate exec use by your applications first.

PHP startup memory exhaustion and worker segfaults `SPLUNK SPL`

```
(index=web OR index=linux) ("exhausted" "Unknown on line 0") OR ("Session ID is too long") OR
("Segmentation fault (11)")
| bin _time span=10m
| stats count by host, _time
| where count > 5
```

Uses the log signatures in S5. Adjust index names. Spikes indicate attempts; confirm compromise with process telemetry.

Linux web server child processes making outbound connections (Defender for Endpoint) `KQL`

```
DeviceProcessEvents
| where Timestamp > ago(7d)
| where InitiatingProcessParentFileName in~ ('apache2','httpd','php-fpm','lsphp','frankenphp') or
InitiatingProcessFileName in~ ('apache2','httpd','php-fpm','lsphp','frankenphp')
| where FileName in~ ('sh','bash','dash','curl','wget','id')
| project Timestamp, DeviceName, AccountName, InitiatingProcessFileName, FileName, ProcessCommandLine
| join kind=leftouter (DeviceNetworkEvents | where Timestamp > ago(7d) | project DeviceName,
NetTime=Timestamp, RemoteIP, RemotePort, InitiatingProcessFileName) on DeviceName, $left.FileName ==
$right.InitiatingProcessFileName
```

Hunting query based on S5 and S1. Add the IP indicators from this report as a watchlist on RemoteIP.

Inbound multipart POST without User-Agent to PHP root paths `SURICATA`

```
alert http $EXTERNAL_NET any -> $HOME_NET any (msg:"Possible PHP2Shell attempt - multipart POST without
User-Agent"; flow:established,to_server; http.method; content:"POST"; http.content_type;
content:"multipart/form-data"; http.user_agent; absent; threshold:type both, track by_src, count 3,
seconds 300; classtype:attempted-admin; sid:9260001; rev:1;)
```

Broad heuristic from the request characteristics in S5. Requires a Suricata version that supports the absent keyword. Expect some false positives; prefer vendor signatures where available.

REMEDIATION ACTIONS

Exposure

Product	Affected	Fixed in	CVE	CVSS	EPSS	CISA KEV	KEV due date
PHP (all web SAPIs: mod_php, PHP-FPM, php-cgi, FrankenPHP, LiteSpeed)	8.2 before 8.2.35; 8.3 before 8.3.36; 8.4 before 8.4.27; 8.5 before 8.5.12	8.2.35, 8.3.36, 8.4.27, 8.5.12 (2026-10-21); Windows builds 8.x.y-1 (2026-10-26)	CVE-2026-109618, CVE-2026-109619	9.2 (CVSS v4.0)	0.99981 / 0.99997 (2026-10-26)	Yes (added 2026-10-26)	2026-10-29
PHP 8.1 and older (end of life)	All	No official release; minimal source backports for 7.4, 8.0, 8.1; distro/LTS vendor backports may exist	CVE-2026-109618, CVE-2026-109619	9.2 (CVSS v4.0)	0.99981 / 0.99997 (2026-10-26)	Yes (added 2026-10-26)	2026-10-29
Products bundling PHP (e.g. Siemens RUGGEDCOM APE1808, Schneider EcoStruxure, B&R APROL, Belden NetModule, Johnson Controls Illustra)	Per vendor advisory	Varies; some have no patch yet	CVE-2026-109618, CVE-2026-109619	9.2 (CVSS v4.0)	0.99981 / 0.99997 (2026-10-26)	Yes (added 2026-10-26)	2026-10-29

Immediate (0–24 hours)

- Inventory every system running PHP, including PHP embedded in appliances, control panels, CMS hosting and OT/building systems. `IT OPS` [S1]
- Patch internet-facing PHP to 8.5.12, 8.4.27, 8.3.36 or 8.2.35 and restart all PHP workers. `IT OPS` [S1] [S12]
- Take offline any internet-facing PHP system that cannot be patched now or runs PHP 8.1 or earlier. `LEADERSHIP` [S1]
- Deploy the detection queries and hunt back to 2026-10-17 for web-server-spawned shells, startup memory-exhaustion errors and worker segfaults. `SOC` [S5] [S1] [S8]

Short term (1–7 days)

- Patch internal PHP systems and track vendor advisories for bundled PHP (Siemens, Schneider Electric, ABB/B&R, Johnson Controls, Belden, HMS, Wibu-Systems, Rockwell, Hitachi Energy). `IT OPS` [S8] [S7]
- For any host showing confirmed shell activity, treat it as compromised: isolate it, preserve logs, rotate credentials and secrets reachable from PHP memory, and rebuild. `SOC` [S5] [S9]
- Apply the Brotli and PHP Windows build updates where PHP runs on Windows or uses the cURL Brotli decoder. `IT OPS` [S7]
- Brief client leadership on KEV status and the 2026-10-29 federal deadline as a benchmark for remediation. `LEADERSHIP` [S2]

Long term

- Migrate off end-of-life PHP branches and maintain a software bill of materials that records bundled runtimes in third-party products. `LEADERSHIP` [S1] [S12]
- Run web workers with least privilege, read-only web roots and restricted egress. These measures limited impact on the honeypots. `IT OPS` [S5]
- Collect process-level telemetry (EDR, auditd or eBPF) on web servers so that post-exploitation activity is visible. `SOC` [S5]

Workarounds & compensating controls

- Enable vendor WAF/CDN/IPS rules for PHP2Shell (for example Palo Alto threat ID 543004). These are partial protection only. `IT OPS` [S1] [S9] [S10]
- Apply PHP's interim hardening where patching is delayed: disable session.upload_progress, set a low post_max_size, and use container or cgroup memory limits. On 8.5, disable fatal_error_backtraces. Restart workers after each change. `IT OPS` [S12]
- Block or rate-limit the listed source IPs for a limited period, and block outbound traffic from web servers to the listed C2 and loader addresses. `SOC` [S5] [S11]

Actions marked with an owner: SOC = security operations, IT Ops = system and network administration, Leadership = risk and communications decisions.

SOURCES

[S1] CISA: Critical Vulnerabilities in PHP Require Immediate Patching
Published 2026-10-21 · `A1` Completely reliable, confirmed by other sources
Primary government alert; updated 2026-10-23 (Sigma rule) and 2026-10-26 (KEV).

[S2] CISA: Known Exploited Vulnerabilities Catalog (JSON feed)
Published 2026-10-26 · `A1` Completely reliable, confirmed by other sources
KEV entries for both CVEs: added 2026-10-26, due 2026-10-29, ransomware use Unknown.

[S3] CVE Program (PHP Group CNA): CVE-2026-109618: RCE via OOM corruption
Published 2026-10-21 · **A1** Completely reliable, confirmed by other sources
CVSS v4.0 9.2, affected/fixed versions, advisory GHSA-w8hw-w9fx-j79w.

[S4] CVE Program (PHP Group CNA): CVE-2026-109619: RCE via stale global state
Published 2026-10-21 · **A1** Completely reliable, confirmed by other sources
CVSS v4.0 9.2, advisory GHSA-6wmf-4rv5-p3rp; record updated 2026-10-27.

[S5] Adel Karimi (honeypot-data): PHP2Shell confirmed RCE on honeypots, 2026-10-24
Published 2026-10-24 · **A2** Completely reliable, probably true
Original researcher data; favorable single-worker mod_php configuration. Source of most IOCs.

[S6] SecurityWeek: PHP2Shell Exploitation Moves From Probes to Working Shells
Published 2026-10-26 · **B2** Usually reliable, probably true
Summarizes the Karimi findings; updated 2026-10-27.

[S7] The Hacker News: CISA Confirms Active Exploitation of PHP2Shell Flaws
Published 2026-10-27 · **B2** Usually reliable, probably true
KEV addition, Censys figure, Brotli flaw and PHP Windows builds.

[S8] SecurityWeek: Industrial Vendors Check Products for PHP2Shell Vulnerabilities
Published 2026-10-26 · **B2** Usually reliable, probably true
Vendor-by-vendor status; first attempt seen 2026-10-17.

[S9] Wiz Research: PHP2Shell: PHP RCE
Published 2026-10-21 · **A2** Completely reliable, probably true
Discoverer write-up; timeline, scope and detection signals.

[S10] Palo Alto Networks Unit 42: Threat Brief: CVE-2026-109618 and CVE-2026-109619 (PHP2Shell)
Published 2026-10-23 · **B2** Usually reliable, probably true
22.6M exposed instances; European government link retracted 2026-10-25.

[S11] The Hacker News: PHP2Shell Exploit Attempts Hit Millions
Published 2026-10-22 · **B3** Usually reliable, possibly true
Compiles Cloudflare, Sophos, Arctic Wolf, Wordfence and SOCRadar/Hunt.io data. Potassium delivery unproven.

[S12] BleepingComputer: PHP ships emergency patches for critical PHP2Shell flaws
Published 2026-10-21 · **B2** Usually reliable, probably true
Affected SAPIs, EOL backports, interim php.ini mitigations.

[S13] FIRST: EPSS API: CVE-2026-109618, CVE-2026-109619
Published 2026-10-26 · **A2** Completely reliable, probably true
EPSS 0.99981 and 0.99997.

Grades use the Admiralty scale: letter = source reliability (A completely reliable to F cannot be judged), number = information credibility (1 confirmed to 6 cannot be judged).

MISCELLANEOUS

Timeline

Date	Event	Source
2026-08-24	Wiz Research reports the flaws to the PHP security team.	[S9]
2026-10-17	First exploitation attempt observed, before the patches.	[S8]
2026-10-21	PHP releases 8.5.12, 8.4.27, 8.3.36 and 8.2.35; CVEs published; CISA issues alert.	[S1] [S3] [S4] [S12]
2026-10-22	Cloudflare reports millions of exploit attempts.	[S11]
2026-10-23	CISA adds a Sigma detection rule to its alert; Unit 42 publishes an update later retracted.	[S1] [S10]
2026-10-24	Honeypots record 35 working shells from two source IPs.	[S5] [S6]
2026-10-25	Unit 42 retracts the European government agency link.	[S10]
2026-10-26	CISA adds both CVEs to KEV; PHP Windows builds patched for the related Brotli flaw.	[S2] [S7]
2026-10-29	KEV remediation due date for federal agencies.	[S2]

Relevance to Indianapolis, Indiana & managed clients

PHP runs a large share of Indiana websites. It powers WordPress and Drupal sites for municipalities, county governments, school districts, universities, healthcare practices and small businesses, and it is common on shared hosting and control panels used by Indianapolis SMBs. Manufacturers and hospitals should check OT, building-management and video systems from Siemens, Schneider Electric, ABB/B&R, Johnson Controls and Belden, because several of these bundle vulnerable PHP and some have no patch yet. For Lucidia IT managed clients, the priority is to find every client-hosted or vendor-hosted PHP instance, confirm hosting providers have patched, patch or isolate internet-facing systems before the 2026-10-29 KEV date, and turn on web-server

process monitoring. Public-sector clients that follow CISA guidance should treat the KEV due date as the benchmark.

Intelligence gaps

- No confirmed compromise of a production (non-honeypot) system has been publicly documented.
- Exploit reliability against multi-worker PHP-FPM, LiteSpeed and FrankenPHP deployments is unknown.
- Whether CVE-2026-109619 has been exploited in the wild, as distinct from CVE-2026-109618, is unclear.
- No threat actor is attributed; whether Potassium was delivered via PHP2Shell is unproven.
- Full vendor coverage of products bundling PHP is incomplete (Rockwell and Hitachi Energy still investigating).
- Wiz notes that untracked variants of the bug class may exist.

Other notes

- Unit 42 retracted its 2026-10-23 update linking an intrusion at a European government agency to PHP2Shell; it cannot confirm the initial access vector.
- Sophos corrected an earlier statement that reported successful Potassium exploitation.
- Sources disagree on whether details leaked before the coordinated release; Wiz describes same-day disclosure, while SecurityWeek says some information leaked online first.
- Related Brotli decoder flaw CVE-2026-111497 (Broccoli2Shell) affects PHP builds on Windows through the cURL extension; PHP issued patched Windows builds on 2026-10-26.

LIT-CTI-20261027-03 v1.1 · Generated 2026-10-27 10:42 EDT from public reporting. Drafted with AI assistance and reviewed by Nick Sturgeon. Verify indicators and actions before operational use. Summaries are in the analyst's own words.

Back to the daily briefing.

TLP:CLEAR Unrestricted public release.